AMMATTIKORKEAKOULU
University of Applied Sciences

Jenna Hemtman

Report
13.5.2026
Enterprise Security and Practitioners
TO00BR91-3011
Deepak Chhetri, Paresh Rathod

Hybrid Office Strategy for Nexus-Global Logistics

AMMATTIKORKEAKOULU
University of Applied Sciences

Report
13.5.2026
Enterprise Security and Practitioners
TO00BR91-3011

Jenna Hemtman
Deepak Chhetri, Paresh Rathod

Table of Contents

1 Introduction 3
2 Executive Summary 4
3 Hardware Security and Secret Management 4
3.1 Anchoring Digital Security with Physical Hardware 4
3.2 Stolen Laptop Scenario 5
3.3 Executive Memo 5
4 Identity Modernization and Comparison 6
4.1 The Psychology of Friction and Passwords 6
4.2 Method Evaluation 6
4.3 The Comparison Table 7
4.4 Logical Diagram 8
5 Governance and Root Cause Analysis (RCA) 8
5.1 Incident: An unauthorized login was detected from a geographically blocked region. 8
5.2 Conclusion of the Analysis 9
5.3 Engineering a Compensating Control 9
6 Practitioner Learning Reflection 9
6.1 Technical vs. Human Behaviour 9
6.2 The Role of the Security Manager 9
6.3 Confidence Check 10
References 11
Use of Artificial Intelligence 11

AMMATTIKORKEAKOULU
University of Applied Sciences

Jenna Hemtman

Report
13.5.2026
Enterprise Security and Practitioners
TO00BR91-3011
Deepak Chhetri, Paresh Rathod

1 Introduction

Use of Artificial Intelligence

During the preparation of this report, Artificial Intelligence was used as an editorial assistant. AI tool Google Gemini was utilized to format the structure of the document, correct grammar, and simplify the language to ensure it is clear and easy to read. All security concepts, technical analysis, and strategic recommendations are the original work of the author.

This report presents a high-level security strategy for Nexus-Global Logistics as the company transitions to a permanent hybrid work model. The focus is on security engineering, which involves building protection directly into daily tools and systems so that safety happens automatically. The primary goal of this strategy is to protect company assets and sensitive data effectively without requiring employees to possess advanced technical knowledge.

As the workforce moves from a centralized office to various remote locations, the traditional methods of protection must be updated. This document outlines a modern approach that prioritizes background security and ease of use. The strategy addresses three critical areas: the use of physical hardware to lock and protect data, the transition from risky passwords to more secure login methods, and the role of management decisions in preventing security breaches. By implementing these measures, Nexus-Global Logistics can ensure that its operations remain secure and efficient, regardless of where the team is working.

Jenna Hemtman
Deepak Chhetri, Paresh Rathod

2 Executive Summary

The move to a permanent hybrid work model at Nexus-Global Logistics requires a new way of thinking about safety and data protection. In this environment, employees are no longer protected by the walls of a physical office, which means the company must change how it secures its assets. There are three primary risks that the company must address to ensure business continuity and protect sensitive information.

The first major risk involves the physical loss of mobile devices. When laptops leave the office, the chance of theft or loss increases. If a device is stolen, the data inside can be easily read by unauthorized people unless the hardware is properly encrypted. Encryption is a process that scrambles information so it can only be read with a special digital key. Without a strong connection between the physical computer parts and this encryption, a thief could simply remove the storage drive and access all company files using a different machine.

The second risk is related to how employees prove their identity when logging in. Most systems still rely on passwords, but these are often the weakest part in security. Hackers frequently use phishing, which is the practice of sending example fake emails or calling via phone pretending to be someone reliable, such as an IT-help desk employee, to trick people into giving away their login details. In a hybrid world, relying on passwords alone is no longer enough because even a careful employee can be tricked, leading to a serious breach of company systems.

The third risk is the presence of outdated technology, often called legacy systems. These are older programs or servers that do not support modern safety features like advanced login methods. Many security failures happen not because of a clever hacker, but because a company has "technical debt," which means they have not invested the necessary budget to update these old systems. If management does not plan for these updates, these old systems remain easy targets for attackers. This report provides a strategy to manage these three risks by using better hardware tools, modern login methods, and proactive management planning.

3 Hardware Security and Secret Management

This section examines the foundation of remote device security by explaining how physical hardware protects sensitive company data. It details the mechanics of hardware-based encryption, demonstrating why physical security chips provide much stronger protection against device theft than software-only solutions. Additionally, this chapter addresses the severe business continuity risks associated with physical hardware failure and outlines the critical need for a centralized cloud recovery system to prevent permanent data loss.

3.1 Anchoring Digital Security with Physical Hardware

To secure data in a remote work environment, computers use a method called encryption. Encryption mathematically scrambles the information on the computer's storage drive so it is

completely unreadable without a specific digital key. To protect this key from hackers, the company uses a physical security chip built directly into the computer's main circuit board. This chip is known as a Trusted Platform Module (TPM).

The TPM acts as a hardware root of trust, meaning the computer's overall security is physically anchored to this specific piece of hardware rather than just software. When a computer turns on, the TPM performs a strict security check before the operating system even loads. It uses components called Platform Configuration Registers, which function like digital tamper-evident seals. These registers inspect the computer's core startup systems to ensure no one has altered them. If the startup process is safe and untampered, the TPM releases the key to unlock the encrypted drive. If any tampering is detected, the vault stays locked, and the computer will not allow access to the data.

3.2 Stolen Laptop Scenario

This physical hardware connection is highly effective if a company laptop is stolen. A common tactic for thieves is to remove the physical storage drive from a stolen laptop and plug it into a different computer. Their goal is to bypass the original computer's password screens and read the files directly. However, because the digital unlock key is physically trapped inside the original laptop's TPM chip, the thief's computer cannot unlock the stolen drive. The data remains securely scrambled.

In contrast, if a company relies only on software-only encryption, the unlock key is often hidden on the storage drive itself. A thief using specialized tools could locate that hidden software key, unlock the drive, and access sensitive company information. By using hardware to hold the key, the company ensures that stolen drives are useless to attackers.

3.3 Executive Memo

As Nexus-Global Logistics implements hardware-based encryption to protect mobile devices, the company must also proactively address a critical business continuity risk known as key loss. Hardware encryption successfully prevents data theft by permanently tying the digital unlock key to a physical chip inside the computer. However, if that specific computer motherboard breaks down due to an electrical short or physical damage, the security chip is destroyed.

When the physical chip dies, the encryption key is lost forever. Consequently, all the logistical data, financial records, and client information stored on that device becomes permanently unreadable, even to our own staff. To prevent this severe loss of data, the company must implement a centralized cloud recovery strategy.

This strategy automatically saves a secure backup of every computer's encryption key to a central, company-controlled online vault. If an employee's computer physically fails, the IT team can retrieve this backup key to unlock the storage drive and recover the files. Funding

and establishing this central recovery system is not merely a technical preference; it is an absolute business necessity to ensure the company never loses critical operational data due to a simple hardware failure.

4 Identity Modernization and Comparison

This section addresses the critical need to transition the company away from vulnerable password systems toward modern, phishing-resistant authentication. It explores how traditional security policies, such as forced password changes, create employee frustration and lead to predictable behaviours that cybercriminals easily exploit. Furthermore, this chapter evaluates different modern login methods—specifically comparing mobile authenticator apps with hardware-based security keys—to help management balance technical protection, financial cost, and daily operational efficiency for the workforce.

4.1 The Psychology of Friction and Passwords

Traditional corporate security policies often require employees to change their passwords every 90 days. While this rule was originally intended to improve safety, this constant forced change creates frustration and leads to predictable human behaviour. When forced to create a new password frequently, employees naturally choose convenience over security. They often take an existing password and simply change a season or a number, such as updating "Winter2026!" to "Spring2026!". Cybercriminals understand this psychology perfectly. If an attacker steals an old password, they can easily guess the new one. Furthermore, constant security prompts on mobile phones cause a dangerous issue known as "MFA fatigue." This happens when tired or distracted employees simply approve any login request on their devices just to make the notifications stop, inadvertently letting hackers into the system.

4.2 Method Evaluation

To protect the business effectively, the company must transition away from weak passwords to modern authentication methods. Two common alternatives are software-based authenticator apps and hardware-based FIDO2 security keys.

Authenticator apps, which are installed on a smartphone, provide a temporary code for logging in. While they offer better protection than a password alone, they are still vulnerable to advanced deception. A hacker can build a fake login website that looks exactly like the real company portal. If an employee is tricked into typing their temporary app code into this fake site, the hacker instantly steals the code and forwards it to the real system. This is known as an Adversary-in-the-Middle attack.

FIDO2 security keys are physical devices that plug into a computer and solve this problem entirely. They provide true phishing resistance. When a user attempts to log in, the physical FIDO2 key automatically checks the underlying mathematical identity of the website's URL. If an employee is tricked into visiting a fake website, the physical key recognizes that the web

address does not match the genuine corporate portal. The key will simply refuse to operate, stopping the attack instantly without relying on the employee to notice the deception.

4.3 The Comparison Table

To assist management in selecting the most effective authentication strategy, the following table compares three primary login methods: traditional passwords, software authenticator apps, and FIDO2 hardware security keys. Each method is evaluated based on its ability to resist modern phishing attacks, the estimated financial cost per user, and the level of friction it introduces to an employee's daily workflow. This comparison highlights the critical balance between strong technical security, budget requirements, and operational efficiency, demonstrating why investing in hardware keys provides the most secure and user-friendly solution for the company.

Table 1: Comparison table of three primary login methods.

Authentication Method	Phishing Resistance Level	Estimated Cost per User	Impact on Employee Speed (Friction)
Traditional Passwords	Low: Easily stolen through fake emails or guessed due to predictable patterns.	$0: Included by default in most operating systems.	High: Causes account lockouts, memory fatigue, and requires constant resets.
Authenticator Apps	Medium: Better than passwords, but vulnerable to fake websites and MFA fatigue.	$0 - $5: Cost of software licensing or mobile management per month.	Medium: Requires the employee to stop working, open a phone, and type a code.
FIDO2 Security Keys	High: Cryptographically bound to the exact website URL; cannot be tricked by fake sites.	$20 - $50: One-time purchase for the physical hardware device.	Low: The employee simply touches the device plugged into their computer.

4.4 Logical Diagram

The FIDO2 secure connection flow operates seamlessly to protect the user from fake websites. First, the employee navigates to the company login portal and enters their username. The company server then recognizes the user and sends a digital request back to the employee's computer. Next, the physical FIDO2 security key plugged into the computer immediately checks the website's address. It compares this address against its internal records to guarantee it is the real company portal and not a fake phishing site. Once the key confirms the site is genuine, it flashes or prompts the employee to physically touch the device. This physical touch proves that a real human is present at the desk, preventing a remote hacker from taking over the login process. Finally, after the touch is registered, the key sends a secure digital signature back to the server, which instantly grants the employee access to the system.

5 Governance and Root Cause Analysis (RCA)

When a security incident occurs, it is critical to look past the immediate technical failure and discover the underlying business reason why the failure was allowed to happen. To achieve this, the company uses the "5-Whys" method. This is a governance tool where investigators ask "why" multiple times until they reach the fundamental root cause of an issue. The following analysis examines a recent simulated security event.

5.1 Incident: An unauthorized login was detected from a geographically blocked region.

1. Why did the unauthorized login happen?

Because an employee's user account was compromised through a phishing attack (a fake email designed to steal passwords).

2. Why was the attacker able to use the stolen password?

Because Multi-Factor Authentication (MFA), which requires a second form of proof to log in, was not activated on that specific account.

3. Why was MFA not activated on that account?

Because the account is tied to an older Human Resources (HR) software application that is technically incapable of supporting modern MFA technologies.

4. Why is the company still using an HR application that cannot support modern security?

Because the application has not been upgraded or replaced in over four years.

5. Why has the application not been upgraded in four years? (The Root Cause)

Because executive management did not allocate a budget for migrating legacy systems or managing "technical debt" during the last financial planning cycle.

5.2 Conclusion of the Analysis

This analysis reveals that the root cause of the security breach was not simply a clever hacker or a careless employee. The true root cause was a governance and budgeting failure. When management does not fund the regular updating of older systems, those systems become structural weaknesses that cybercriminals can easily exploit.

5.3 Engineering a Compensating Control

Since upgrading the HR application will require time and a new budget allocation, the company must immediately implement a temporary security measure to protect the vulnerable system. This is known as a compensating control. To secure the legacy application, the IT department will enforce the following Conditional Access policy, written here in plain English: "Access to the legacy HR portal is strictly restricted. Any attempt to log in will be blocked unless the employee is actively connected to the secure Corporate VPN and is using a verified, company-owned device equipped with a valid security certificate." This policy completely bypasses the weak password issue by checking the physical location of the network connection and the mathematical identity of the laptop itself before even asking for a password.

6 Practitioner Learning Reflection

This final section of the report is my personal reflection on the core principles guiding this security strategy. I will outline why I believe that technical security tools must account for natural human behaviour to be truly effective, rather than simply adding frustration to daily tasks. Additionally, I reflect on the critical role that management decisions play in preventing security breaches, and how I intend to communicate the direct financial value of modern security investments to business leaders.

6.1 Technical vs. Human Behaviour

In my analysis of user friction, I concluded that a technically perfect but difficult-to-use security tool does not make our company safer. If I implement security measures that cause excessive frustration, employees will inevitably create unsecure workarounds just to finish their daily tasks. I have learned that true corporate safety is achieved only when the protective measures I design seamlessly integrate with natural human behaviour.

6.2 The Role of the Security Manager

Through performing the root cause analysis, I realized why I must look beyond immediate hacker activity and identify underlying budget or policy failures. These administrative decisions dictate the structural strength of the technical defences I manage. I now understand that by addressing these management-level failures, I can help the business proactively eliminate vulnerabilities at their source rather than just constantly reacting to individual attacks.

6.3 Confidence Check

I now feel confident explaining to business owners why investing in passwordless technology is a financial necessity rather than just an IT upgrade. I can clearly demonstrate that telling employees to simply “be more careful” is an ineffective strategy against modern phishing campaigns. Instead, I can show how hardware-based authentication provides a measurable return on investment by physically preventing attacks and recovering the daily productivity lost to constant password resets.

AMMATTIKORKEAKOULU
University of Applied Sciences

Jenna Hemtman

Report
13.5.2026
Enterprise Security and Practitioners
TO00BR91-3011
Deepak Chhetri, Paresh Rathod

References

Birch, M. 2025. CompTIA® SecurityX® CAS-005 Certification Guide: Master advanced security strategies and confidently take the new CAS-005 exam. Second Edition. Birmingham. Packet Publishing.

Unpublished sources

Enterprise Security and Practitioners course material. The Practitioner Scenario - Nexus-Global Logistics. 2026. Laurea University of Applied Sciences.

Use of Artificial Intelligence

During the preparation of this report, Artificial Intelligence was used as an editorial assistant. AI tool Google Gemini was utilized to format the structure of the document, correct grammar, and simplify the language to ensure it is clear and easy to read. All security concepts, technical analysis, and strategic recommendations are the original work of the author.